BIZU DO CONCURSEIRO X APOSTILA

GCM · GUARDA CIVIL MUNICIPAL

NOÇÕES DE INFORMÁTICA

SEGURANÇA DA INFORMAÇÃO

CONCURSO

Guarda Civil Municipal (GCM)

DISCIPLINA

Noções de Informática

BANCA

Variadas (VUNESP e outras bancas de concursos municipais)

15	8	20
seções	quadros	questões comentadas

Gerado em 11/11/2026 a partir da versão atual do material no site.

Nesta apostila

1 APRESENTAÇÃO DO TEMA 3
2 BASE TEÓRICA E NORMATIVA 4
3 CONCEITOS FUNDAMENTAIS 5
4 DESENVOLVIMENTO DOUTRINÁRIO 6
5 REGRAS E EXEMPLOS 10
6 QUADRO COMPARATIVO / DIFERENCIAÇÕES 11
7 APLICAÇÃO NA PROVA 13
8 PONTOS CRÍTICOS (O QUE MAIS CAI NA BANCA) 13
9 PEGADINHAS CLÁSSICAS 14
10 QUESTÕES NO ESTILO DA BANCA (COM GABARITO COMENTADO) 15
11 RESUMO DA VÉSPERA 18
Estudo completo do assunto — material integrado 19
Mapa mental do assunto 19
Bateria de questões resolvidas 20
Revisão rápida — perguntas e respostas 24
Vídeos complementares 24

1 APRESENTAÇÃO DO TEMA

A informação é um dos bens mais valiosos de uma instituição. Em órgãos de segurança pública, ela pode ser **sigilosa, pessoal e sensível**: registros de ocorrências, dados de cidadãos atendidos, escalas de serviço, imagens de câmeras. Proteger essa informação é tarefa de **todos** os que usam computador, celular ou rede, e não apenas do setor de tecnologia.

O conteúdo desse assunto reúne dois blocos. O primeiro é **conceitual**: princípios da segurança, criptografia, hash, assinatura digital, autenticação e backup. O segundo é **prático**: tipos de malware, golpes por e-mail e aplicativo de mensagens, senhas fracas, compartilhamento de arquivos e conduta do agente público.

As questões costumam apresentar um **cenário** (um e-mail suspeito, um arquivo que travou, uma senha reaproveitada) e pedir o **nome da ameaça** ou a **medida correta de proteção**. Dominar as definições de cada tipo de malware, a diferença entre os tipos de backup e o conceito de autenticação resolve boa parte dos itens.

Os subtópicos tratados nesta apostila são:

- princípios da segurança da informação, criptografia, hash e assinatura digital;
- senhas e autenticação;
- cópias de segurança (backup);
- malware e proteção;
- phishing e engenharia social;
- fraudes eletrônicas;
- privacidade e compartilhamento seguro;
- uso ético e seguro dos recursos de TI.

> **BIZU**
>
> Em prova, a resposta mais segura costuma ser a que combina **prevenção** (senha forte, autenticação em dois fatores, atualização), **detecção** (antivírus, firewall) e **recuperação** (backup testado). Desconfie de alternativas que prometam proteção total com uma única medida.

Objetivos de aprendizagem

Ao final, você deverá ser capaz de:

- explicar os princípios da segurança da informação (confidencialidade, integridade, disponibilidade e autenticidade);
- criar e avaliar senhas e explicar a autenticação em dois fatores;
- distinguir backup completo, incremental e diferencial e planejar a restauração;
- classificar os tipos de malware e indicar as medidas de proteção adequadas;
- reconhecer phishing, engenharia social e fraudes eletrônicas e agir diante delas;
- aplicar práticas de privacidade, de compartilhamento seguro e de uso ético dos recursos de TI no serviço público.

2 BASE TEÓRICA E NORMATIVA

Informática é, em regra, matéria de **conhecimento consolidado**, sem lei seca para decorar. Neste assunto, porém, duas normas aparecem como referência e vale conhecê-las pelo que dizem de forma geral.

2.1. Lei Geral de Proteção de Dados Pessoais (LGPD)

A **Lei nº 13.709/2018** regula o tratamento de dados pessoais no Brasil e alcança também o **poder público**. O artigo de abertura define o seu alcance:

> **LEI SECA**
>
> **Lei nº 13.709/2018 (LGPD), art. 1º, caput**
>
> Esta Lei dispõe sobre o tratamento de dados pessoais, inclusive nos meios digitais, por pessoa natural ou por pessoa jurídica de direito público ou privado, com o objetivo de proteger os direitos fundamentais de liberdade e de privacidade e o livre desenvolvimento da personalidade da pessoa natural.

Três ideias saem desse artigo:

- a lei trata do **tratamento de dados pessoais**, inclusive nos meios digitais;
- ela vale para **pessoa natural** e para **pessoa jurídica de direito público ou privado**, o que inclui órgãos públicos como a prefeitura e a guarda municipal;
- o objetivo é proteger a **liberdade**, a **privacidade** e o **livre desenvolvimento da personalidade** da pessoa natural.

O **dado pessoal** é a informação relacionada a pessoa natural identificada ou identificável. Em conceito geral, o titular dos dados tem direitos sobre eles, e quem trata os dados deve fazê-lo de forma adequada e segura. O aprofundamento da LGPD pertence ao assunto específico do edital sobre proteção de dados.

2.2. Invasão de dispositivo informático

A invasão de dispositivo informático é crime previsto no **Código Penal, art. 154-A**, introduzido pela Lei nº 12.737/2012 e depois alterado. Para esta apostila, basta saber que a conduta de invadir dispositivo alheio, conectado ou não à rede, é tipificada como crime. Como o dispositivo sofreu alterações, as penas não são tratadas aqui: consulte o texto vigente do Código Penal.

> **ATENÇÃO**
>
> Não decore penas de crimes informáticos a partir de apostilas antigas. O art. 154-A foi alterado depois de sua criação. Para a prova de Informática, o que cai é o **conceito** e a **medida de proteção**, não a pena.

3 CONCEITOS FUNDAMENTAIS

3.1. Princípios da segurança da informação

A segurança da informação busca proteger dados e sistemas contra acessos indevidos, alterações e interrupções. Seus princípios básicos formam a sigla **CID** (confidencialidade, integridade, disponibilidade), muitas vezes ampliada com a **autenticidade**.

Princípio	Significado	Violação típica
Confidencialidade	Só quem está autorizado acessa	Vazamento de dados
Integridade	A informação não é alterada indevidamente	Adulteração de um documento
Disponibilidade	A informação está acessível quando necessária	Sistema fora do ar por ataque
Autenticidade	Confirma a autoria e a origem	Mensagem de falso remetente

Também se fala em **não repúdio** (irretratabilidade): o autor de uma ação não pode negar tê-la praticado, algo garantido, por exemplo, pela **assinatura digital**.

3.2. Ameaça, vulnerabilidade e risco

- **Ameaça:** algo que pode causar dano (um vírus, um invasor, um incêndio).
- **Vulnerabilidade:** fraqueza que pode ser explorada (um programa desatualizado, uma senha fraca).
- **Risco:** a chance de a ameaça explorar a vulnerabilidade e causar impacto.

> **EXEMPLO**
>
> Um computador com o sistema desatualizado (vulnerabilidade) está ligado à internet, onde circulam programas maliciosos que exploram essa falha (ameaça). A chance de a máquina ser infectada e de os dados serem perdidos é o risco. Atualizar o sistema reduz a vulnerabilidade e, com isso, o risco.

3.3. Criptografia, hash e assinatura digital

A **criptografia** transforma a informação em um formato ilegível, que só pode ser lido por quem tem a chave.

- **Criptografia simétrica:** a mesma chave cifra e decifra. É rápida, mas exige que a chave seja compartilhada com segurança.
- **Criptografia assimétrica:** usam-se duas chaves matematicamente ligadas, a **pública** (divulgada) e a **privada** (secreta). O que é cifrado com a chave pública só se decifra com a privada correspondente, o que garante **confidencialidade**.

A **assinatura digital** faz o caminho inverso: o autor usa sua **chave privada** para assinar, e qualquer pessoa confere com a **chave pública**. Ela garante **autenticidade, integridade e não repúdio**.

O **hash** é um resumo de tamanho fixo calculado a partir do conteúdo. Se o arquivo mudar um único caractere, o hash muda, o que permite **verificar a integridade**. O hash não é uma forma de cifrar para depois decifrar: ele serve para conferir se o conteúdo é o mesmo.

O **certificado digital** associa uma chave pública a uma pessoa ou instituição. É emitido por uma **autoridade certificadora** e, no Brasil, dentro da estrutura da **ICP-Brasil**.

> **BIZU**
>
> Cifrar para que só o destinatário leia: **chave pública do destinatário** (confidencialidade). Assinar para provar autoria: **chave privada do autor** (autenticidade, integridade e não repúdio).

4 DESENVOLVIMENTO DOUTRINÁRIO

DOUTRINA

4.1. Senhas e autenticação

A **autenticação** confirma que quem tenta acessar um sistema é realmente quem diz ser. Existem **três categorias de fator**:

- **algo que você sabe:** senha, PIN;
- **algo que você tem:** celular, token, cartão;
- **algo que você é:** biometria (digital, face, íris).

A **autenticação em dois fatores (2FA)** exige dois fatores de **categorias diferentes**, como senha mais código enviado ao celular. Duas senhas diferentes são o **mesmo fator**, e não dois fatores.

> **ATENÇÃO**
>
> Senha mais pergunta de segurança, ou senha mais outra senha, não é 2FA de verdade, pois ambos os itens são "algo que você sabe". Os dois fatores devem ser de naturezas diferentes.

4.1.1. Boas práticas com senhas

- Prefira senhas **longas** (frases-senha com 12 caracteres ou mais), com letras maiúsculas e minúsculas, números e símbolos.
- Não use **dados pessoais** (nome, data de nascimento, placa de carro, número de telefone) nem sequências óbvias (123456, qwerty).
- Use uma senha **diferente para cada serviço**: se uma vazar, as demais continuam seguras.
- Use um **gerenciador de senhas** confiável para guardar as senhas, em vez de anotá-las em papel à vista.
- **Nunca compartilhe** senhas nem códigos de verificação, nem com pessoas conhecidas.
- **Troque a senha imediatamente** se houver suspeita de vazamento.

4.1.2. Ataques às senhas

- **Força bruta:** tentar todas as combinações possíveis.
- **Ataque de dicionário:** testar palavras comuns e suas variações.
- **Reuso de senhas vazadas:** o criminoso testa, em outros sites, a senha que vazou em um deles.

Por isso o **tamanho e a variedade** da senha importam, e o 2FA reduz o risco mesmo quando a senha é descoberta. A **biometria** é um fator conveniente, mas, ao contrário da senha, não pode ser trocada se for

comprometida.

4.1.3. Gerenciador de senhas

O gerenciador de senhas armazena as credenciais de forma protegida (cifrada), em geral atrás de uma **senha mestra**. Ele facilita o uso de senhas longas, complexas e diferentes em cada serviço, sem que o usuário precise memorizá-las. Ele **não faz backup** dos arquivos nem substitui o antivírus.

4.2. Cópias de segurança (backup)

O **backup** é uma cópia dos dados guardada em outro local para permitir a recuperação em caso de pane, furto, exclusão acidental, desastre ou ataque de ransomware. Backup **não é** o mesmo que armazenar um arquivo em duas pastas do mesmo disco, pois uma falha do disco atinge as duas cópias.

4.2.1. Tipos de backup

Tipo	O que copia	Para restaurar
Completo (normal)	Todos os dados selecionados	Apenas o último completo
Incremental	O que mudou desde o último backup de qualquer tipo	Completo + todos os incrementais
Diferencial	O que mudou desde o último backup completo	Completo + o último diferencial

O **completo** é o mais lento e ocupa mais espaço, mas é o mais simples de restaurar. O **incremental** é o mais rápido e econômico para fazer, porém a restauração é mais trabalhosa, pois depende da cadeia inteira. O **diferencial** fica no meio-termo: cresce a cada dia, mas na restauração bastam duas partes.

> **EXEMPLO**
>
> No domingo faz-se o backup completo. Na segunda, mudam 5 GB; na terça, mais 3 GB; na quarta, mais 4 GB.
>
> **Incremental:** os backups de segunda, terça e quarta têm 5, 3 e 4 GB (total de 12 GB), e restaurar a quarta exige o completo mais os três incrementais.
>
> **Diferencial:** os backups têm 5, 8 e 12 GB (total de 25 GB), e restaurar a quarta exige o completo mais o diferencial de quarta.

4.2.2. Boas práticas de backup

- manter **ao menos uma cópia fora do local** (em outra sala, em mídia guardada em outro prédio ou na nuvem);
- executar backups **periódicos e automáticos**;
- **proteger as cópias**, inclusive com criptografia;
- **testar a restauração**, pois um backup que nunca foi testado pode estar inutilizável.

Uma regra conhecida é a **3-2-1**: **três** cópias dos dados, em **duas** mídias diferentes, sendo **uma** delas fora do local.

4.3. Malware e proteção

Malware (software malicioso) é todo programa criado para causar dano, roubar informações ou obter acesso indevido. Cada tipo tem um comportamento característico, e as questões pedem justamente esse reconhecimento.

Tipo	Característica
Vírus	Anexa-se a arquivos e precisa ser executado para agir e se propagar
Worm	Espalha-se sozinho pela rede, sem hospedeiro nem ação do usuário
Cavalo de Troia (trojan)	Aparenta ser útil, mas executa ações ocultas
Ransomware	Criptografa os dados e exige resgate
Spyware	Espiona a atividade do usuário
Keylogger / screenlogger	Registra teclas digitadas / capturas da tela
Adware	Exibe propaganda indesejada
Backdoor	Abre uma porta de acesso remoto escondida
Rootkit	Esconde a presença do invasor e de outros códigos
Botnet	Rede de máquinas infectadas controladas à distância

> **ATENÇÃO**
>
> **Vírus e worm não são a mesma coisa.** O vírus depende de um arquivo hospedeiro e de uma ação do usuário; o worm se propaga sozinho. O cavalo de Troia, por sua vez, não se replica: ele depende de o usuário instalá-lo, enganado pela aparência de programa legítimo.

4.3.1. Ransomware

O ransomware é um dos maiores riscos atuais: **sequestra os arquivos por criptografia** e cobra pagamento para liberá-los. A melhor defesa é o **backup** feito com antecedência e mantido **isolado** da máquina. O pagamento do resgate **não garante** a recuperação dos dados e financia o crime.

4.3.2. Medidas de proteção

- manter o **antivírus** atualizado e ativo;
- ativar o **firewall**, que filtra o tráfego de rede entre o computador e a internet e bloqueia conexões não autorizadas;
- manter o **sistema e os programas atualizados** para corrigir vulnerabilidades;
- baixar programas **só de fontes oficiais**;
- desconfiar de anexos e links;
- usar uma **conta de usuário comum** no dia a dia, reservando a conta de administrador para tarefas que a exijam.

O firewall **não substitui** o antivírus: um bloqueia conexões, o outro detecta e remove códigos maliciosos.

4.3.3. Outros ataques

- **Negação de serviço (DoS/DDoS):** sobrecarrega um serviço para torná-lo indisponível. Fere o princípio da **disponibilidade**. No DDoS, o ataque parte de muitas máquinas ao mesmo tempo.
- **Sniffing:** captura o tráfego da rede. Fere a **confidencialidade** quando o conteúdo não está cifrado.

4.4. Phishing, engenharia social e fraudes eletrônicas

A **engenharia social** é o conjunto de técnicas que enganam pessoas, explorando confiança, medo, urgência, curiosidade ou vontade de ajudar, para obter dados ou levá-las a executar ações. O elo mais fraco da segurança costuma ser o **fator humano**, e por isso a conscientização é parte essencial da proteção.

O **phishing** é a mensagem fraudulenta, enviada por e-mail, SMS, aplicativo de mensagens ou rede social, que imita uma instituição (banco, órgão público, loja, transportadora) para fisgar a vítima e roubar senhas, códigos e dados.

- **Smishing:** o phishing por SMS.
- **Vishing:** o phishing por ligação telefônica.
- **Pharming:** redireciona o usuário a um site falso mesmo que ele digite o endereço correto, por meio de adulteração do DNS.
- **Spoofing:** falsifica a identidade do remetente (e-mail ou número de telefone).

4.4.1. Fraudes mais comuns

- **Boleto adulterado:** o código de barras leva o pagamento a outra conta. Confira o beneficiário antes de pagar.
- **Falso atendente de banco:** liga ou envia mensagem dizendo que há movimentação suspeita e pede senha, token ou "transferência de segurança".
- **Falso parente ou amigo:** mensagem de número desconhecido pedindo dinheiro com urgência.
- **Falsa central de vendas ou loja virtual:** preço muito abaixo do mercado e pagamento fora da plataforma.
- **Pedido do código de verificação** do aplicativo de mensagens: serve para clonar a conta.

4.4.2. Sinais de alerta

- urgência ou ameaça;
- erros de português;
- remetente estranho;
- endereço do link diferente do que aparece no texto, ou link encurtado;
- anexos inesperados (principalmente .exe, .zip ou documentos que pedem para habilitar macros);
- pedido de senha, código ou dados bancários.

Instituições sérias **não pedem senha ou código por mensagem**. Na dúvida, não clique: acesse o site digitando o endereço, ou entre em contato por canal oficial.

> **PEGADINHA**
>
> O **cadeado** do navegador indica apenas que a conexão é cifrada (HTTPS), e **não** que o site é honesto. Sites falsos também podem usar HTTPS. Confira o domínio e a origem do link.

4.5. Privacidade, compartilhamento seguro e uso ético

A **privacidade** diz respeito ao controle sobre os dados pessoais. No Brasil, o tratamento desses dados é regulado pela LGPD (item 2.1).

4.5.1. Compartilhamento seguro

- Compartilhe arquivos com **pessoas específicas** e com a **permissão mínima necessária** (só leitura, quando bastar).
- Evite enviar documentos sigilosos por canais não autorizados ou por aplicativos pessoais.
- **Revise periodicamente** quem tem acesso a pastas e documentos e remova acessos desnecessários.
- Em redes **Wi-Fi públicas**, evite acessar banco ou sistemas sensíveis; se necessário, use **VPN**.
- Verifique o destinatário antes de enviar; no e-mail, cuidado com "Responder a todos" e com o uso de **Cc em vez de Cco** (cópia oculta).
- Em redes sociais, divulgue o mínimo de dados pessoais, de rotina e de localização: informações pessoais ajudam golpistas e criminosos.

4.5.2. Uso ético e seguro no serviço público

O agente público deve usar equipamentos, sistemas e redes da instituição **apenas para fins do serviço**, seguindo as normas internas. São condutas esperadas:

- **bloquear a tela** ao se afastar (no Windows, pelas teclas Windows + L);
- não emprestar senha, crachá ou token;
- acessar somente as informações **necessárias à sua função**;
- não divulgar informação sigilosa;
- não instalar programas piratas ou não autorizados;
- **comunicar imediatamente** ao setor responsável qualquer incidente, como perda de equipamento, e-mail suspeito ou suspeita de invasão.

> **BIZU**
>
> Se o candidato lê "emprestar a senha a um colega de confiança", "deixar a sessão aberta ao sair" ou "publicar dados de ocorrência nas redes", a alternativa está errada. A senha é pessoal e intransferível, e os dados de ocorrências são sigilosos.

5 REGRAS E EXEMPLOS

5.1. Exemplo: identificar o ataque

Um servidor recebe e-mail em nome do "setor de TI" pedindo que ele clique em um link e informe a senha para "evitar o bloqueio da conta em 2 horas". Que tipo de ataque é esse e qual a conduta correta?

A mensagem imita uma área legítima e usa **urgência e ameaça** para obter a senha: é **phishing**, uma técnica de engenharia social. A conduta é **não clicar, não informar a senha** e comunicar o setor de segurança ou de TI por canal oficial.

5.2. Exemplo: comparar backups

Uma empresa faz backup completo aos domingos. Na segunda, terça e quarta, as alterações novas foram de 5 GB, 3 GB e 4 GB.

- **Incremental:** copia o que mudou desde o último backup de qualquer tipo: 5, 3 e 4 GB, total de **12 GB**. Restaurar a quarta: completo e três incrementais.
- **Diferencial:** copia tudo desde o último completo: 5, 5+3 = 8 e 5+3+4 = 12 GB, total de **25 GB**. Restaurar a quarta: completo e diferencial de quarta.

5.3. Exemplo: classificar o malware

Um usuário baixou um "cartão virtual" que, ao ser aberto, passou a registrar tudo o que ele digitava, inclusive senhas, e a enviar os dados a terceiros. O arquivo se passou por algo inofensivo, o que caracteriza **cavalo de Troia**. O comportamento de registrar as teclas digitadas é o de um **keylogger**, um tipo de **spyware**.

5.4. Exemplo: 2FA ou não?

Em um sistema, o login exige a senha do usuário e, em seguida, a resposta a uma pergunta de segurança. **Não** é autenticação em dois fatores: senha e resposta a uma pergunta são ambas informações que o usuário **sabe**, ou seja, do mesmo tipo de fator. Dois fatores de verdade exigiriam categorias diferentes, como senha e código no celular.

5.5. Exemplo: cifrar ou assinar?

Para enviar um documento de forma que **somente o destinatário** consiga lê-lo, o remetente cifra com a **chave pública do destinatário**; só a chave privada dele decifra. Para que o destinatário tenha certeza de que o documento veio do remetente e não foi alterado, o remetente **assina** com a **sua chave privada**; o destinatário confere com a chave pública do remetente.

5.6. Exemplo: o que fazer diante de um anexo suspeito

Chega um e-mail de um remetente desconhecido com um anexo .zip e o texto "fatura em atraso, abra imediatamente". Sinais de alerta: remetente estranho, urgência, anexo inesperado. A conduta correta é **não abrir o anexo**, não clicar em links, apagar ou encaminhar a mensagem ao setor de TI, conforme a norma interna, e, se abriu por engano, **desconectar a máquina da rede** e comunicar o incidente.

6 QUADRO COMPARATIVO / DIFERENCIAÇÕES

COMPARAÇÃO

6.1. Backup completo, incremental e diferencial

Aspecto	Completo	Incremental	Diferencial
Referência	Todos os dados	Último backup de qualquer tipo	Último backup completo
Velocidade de fazer	Mais lento	Mais rápido	Intermediária
Espaço ocupado	Maior	Menor	Intermediário (cresce a cada dia)

Aspecto	Completo	Incremental	Diferencial
Restauração	Só o último completo	Completo + todos os incrementais	Completo + último diferencial

6.2. Vírus, worm e cavalo de Troia

Tipo	Precisa de hospedeiro?	Replica-se sozinho?	Característica central
Vírus	Sim, anexa-se a arquivos	Depende de execução do usuário	Infecta arquivos
Worm	Não	Sim, pela rede	Propaga-se sem ação do usuário
Cavalo de Troia	Não	Não	Disfarça-se de programa útil

6.3. Chaves: cifrar e assinar

Objetivo	Quem usa	Qual chave	Garante
Cifrar	Remetente	Chave pública do destinatário	Confidencialidade
Assinar	Autor	Chave privada do autor	Autenticidade, integridade e não repúdio
Decifrar	Destinatário	Chave privada do destinatário	Leitura do conteúdo
Conferir assinatura	Qualquer pessoa	Chave pública do autor	Verificação de autoria

6.4. Fatores de autenticação

Fator	Exemplos
Algo que você sabe	Senha, PIN, resposta secreta
Algo que você tem	Celular, token, cartão
Algo que você é	Digital, face, íris

COMPARAÇÃO

Antivírus detecta e remove códigos maliciosos. **Firewall** filtra conexões de rede. **Backup** permite recuperar os dados. **Criptografia** protege o sigilo. Nenhum substitui os outros: eles se complementam.

7 APLICAÇÃO NA PROVA

Em Informática, a prova costuma trazer **situações do dia a dia do serviço público** para testar se o candidato reconhece a ameaça e escolhe a conduta correta. Alguns padrões de enunciado:

- **"Mensagem com urgência pedindo senha ou clique em link":** phishing. A resposta correta nunca é clicar ou informar a senha.
- **"Arquivos que ficaram inacessíveis e há pedido de pagamento":** ransomware. A defesa é o backup isolado, e pagar não garante recuperação.
- **"Programa que parecia inofensivo e executa ações ocultas":** cavalo de Troia.
- **"Programa que se espalha pela rede sozinho":** worm.
- **"Registra o que o usuário digita":** keylogger (spyware).
- **"Só precisa do último completo e do último diferencial":** backup diferencial.
- **"Senha e código no celular":** 2FA. **"Senha e pergunta de segurança":** não é 2FA.
- **"O cadeado garante que o site é seguro":** errado, o cadeado indica apenas conexão cifrada.
- **"Conduta do agente público":** a correta protege o sigilo, não empresta credenciais, bloqueia a tela e comunica incidentes.

DOUTRINA

A segurança da informação é um **processo**, e não um produto. Tecnologia ajuda, mas o fator humano decide: muitas invasões começam por um clique desatento. Por isso a banca valoriza condutas de prevenção e de comunicação de incidentes.

8 PONTOS CRÍTICOS (O QUE MAIS CAI NA BANCA)

MAIS COBRADO

O QUE MAIS CAI

- **Princípios CID** e a violação típica de cada um (vazamento, adulteração, indisponibilidade).
- **Vírus x worm:** o vírus precisa de arquivo hospedeiro e execução; o worm se propaga sozinho pela rede.
- **Incremental x diferencial:** incremental é desde o último backup de qualquer tipo; diferencial é desde o último completo.
- **2FA:** dois fatores de categorias diferentes (saber, ter, ser).
- **Firewall x antivírus:** um filtra conexões de rede, o outro detecta e remove malware.
- **Cifrar x assinar:** cifrar usa a chave pública do destinatário; assinar usa a chave privada do autor.
- **Cadeado do navegador:** indica só conexão cifrada, não prova que o site é honesto.
- **Ransomware:** a defesa é o backup, e o pagamento do resgate não garante a recuperação.
- **Phishing e variações:** smishing (SMS), vishing (voz), pharming (DNS), spoofing (falsa identidade).
- **LGPD, art. 1º:** alcança pessoa natural e pessoa jurídica de direito público ou privado.

- **Conduta do agente público:** sigilo, senha pessoal, bloqueio da tela, comunicação de incidentes.

REVISÃO

Pergunte-se diante de cada questão: qual princípio foi violado (CID)? Qual o tipo de ameaça (nome do malware ou do golpe)? Qual medida de prevenção, detecção ou recuperação resolve? A resposta quase sempre cabe em uma dessas três perguntas.

9 PEGADINHAS CLÁSSICAS

PEGADINHA

PEGADINHA

✗ *"Vírus e worm são o mesmo tipo de código malicioso."*
Falso. O vírus depende de um arquivo hospedeiro e de uma ação do usuário; o worm se propaga sozinho pela rede.

✗ *"O backup incremental copia tudo o que mudou desde o último backup completo."*
Falso. Isso descreve o diferencial. O incremental copia o que mudou desde o último backup de qualquer tipo.

✗ *"Autenticação em dois fatores é o uso de duas senhas diferentes."*
Falso. Duas senhas são o mesmo fator (algo que se sabe). A 2FA exige fatores de categorias diferentes.

✗ *"O firewall dispensa o uso de antivírus."*
Falso. O firewall filtra o tráfego de rede; o antivírus detecta e remove códigos maliciosos. Eles se complementam.

✗ *"O cadeado no navegador garante que o site é legítimo e seguro."*
Falso. O cadeado indica apenas conexão cifrada; sites fraudulentos também podem usá-lo.

✗ *"Para enviar um arquivo que só o destinatário leia, o remetente cifra com a própria chave privada."*
Falso. Para garantir sigilo, cifra-se com a chave pública do destinatário. A chave privada do autor serve para assinar.

✗ *"Manter o backup no mesmo disco do arquivo original é suficiente."*
Falso. Uma falha no disco atinge as duas cópias. É preciso manter cópia em outro local.

✗ *"Pagar o resgate do ransomware garante a devolução dos dados."*
Falso. O pagamento não garante a recuperação e financia o crime. A defesa é o backup feito com antecedência.

✗ *"A biometria é mais segura porque pode ser trocada quando comprometida."*
Falso. Ao contrário da senha, a biometria não pode ser trocada se for comprometida.

✗ *"Instituições sérias podem pedir a senha por mensagem para confirmar sua identidade."*
Falso. Instituições sérias não pedem senha ou código por mensagem.

10 QUESTÕES NO ESTILO DA BANCA (COM GABARITO COMENTADO)

TREINO

QUESTÃO 01

O vazamento de dados sigilosos de um sistema de ocorrências para pessoas não autorizadas fere, principalmente, o princípio da

A) disponibilidade.
B) confidencialidade.
C) integridade.
D) autenticidade.

Gabarito: B.

A confidencialidade garante que só quem está autorizado acessa a informação, e o vazamento é a sua violação típica. A disponibilidade é ferida quando o sistema fica fora do ar; a integridade, quando o dado é alterado indevidamente; a autenticidade, quando se falsifica a origem ou a autoria.

QUESTÃO 02

Uma servidora quer enviar um documento de modo que somente o destinatário consiga lê-lo, usando criptografia assimétrica. Para isso, ela deve cifrar o documento com

A) a sua chave privada.
B) a sua chave pública.
C) a chave privada do destinatário.
D) a chave pública do destinatário.

Gabarito: D.

O que é cifrado com a chave pública só é decifrado com a chave privada correspondente. Cifrando com a chave pública do destinatário, só ele, que guarda a privada, poderá ler. Cifrar com a própria chave privada é o mecanismo da assinatura digital, que prova autoria mas não impede a leitura por terceiros. A chave privada do destinatário é secreta e não está disponível à remetente.

QUESTÃO 03

Uma instituição faz backup completo aos domingos e backups incrementais de segunda a quarta-feira. Para restaurar os dados do final da quarta-feira, serão necessários

A) o backup completo de domingo e os três incrementais, de segunda, terça e quarta.
B) apenas o incremental de quarta-feira.
C) o backup completo de domingo e apenas o incremental de quarta-feira.
D) apenas o backup completo de domingo.

Gabarito: A.

No esquema incremental, cada cópia contém somente o que mudou desde o último backup de qualquer tipo. Por isso a restauração depende de toda a cadeia: o completo mais todos os incrementais, na ordem. Se fosse diferencial, bastariam o completo e o último diferencial (alternativa C descreveria o diferencial, não o incremental).

QUESTÃO 04

Uma equipe faz backup completo aos domingos. Na segunda-feira mudam 6 GB; na terça, mais 2 GB; na quarta, mais 3 GB. Comparando o espaço total ocupado pelos backups de segunda a quarta no esquema diferencial e no esquema incremental, o diferencial ocupa a mais

A) 11 GB.
B) 25 GB.
C) 14 GB.
D) 8 GB.

Gabarito: C.

Incremental: 6 + 2 + 3 = 11 GB. Diferencial: segunda 6 GB; terça 6 + 2 = 8 GB; quarta 6 + 2 + 3 = 11 GB; total 6 + 8 + 11 = 25 GB. A diferença é 25 - 11 = 14 GB. A alternativa A é o total do incremental; a B é o total do diferencial; a D é apenas o backup diferencial de terça.

QUESTÃO 05

Um programa malicioso se propaga automaticamente pela rede, explorando falhas dos sistemas, sem precisar de arquivo hospedeiro nem de qualquer ação do usuário. Esse comportamento é típico de

A) worm.
B) vírus.
C) cavalo de Troia.
D) adware.

Gabarito: A.

O worm se espalha sozinho pela rede. O vírus precisa de arquivo hospedeiro e de execução; o cavalo de Troia aparenta ser útil e depende de o usuário instalá-lo; o adware exibe propaganda

indesejada.

QUESTÃO 06

Entre as opções a seguir, a que configura autenticação em dois fatores de categorias diferentes é

A senha e resposta a uma pergunta de segurança.
B duas senhas distintas digitadas em sequência.
C senha e um segundo PIN numérico.
D senha e código gerado em um aplicativo no celular do usuário.

Gabarito: D.

A senha é algo que o usuário sabe, e o código do aplicativo no celular depende de algo que ele tem: categorias diferentes. As alternativas A, B e C combinam dois itens de conhecimento (algo que se sabe), que são o mesmo fator.

QUESTÃO 07

Um usuário digita corretamente o endereço do site do seu banco, mas é levado a uma página falsa, idêntica à original, porque o sistema de nomes (DNS) foi adulterado. Essa técnica é conhecida como

A smishing.
B pharming.
C vishing.
D keylogger.

Gabarito: B.

O pharming redireciona o usuário a um site falso mesmo que ele digite o endereço correto, por meio de adulteração do DNS. O smishing é o phishing por SMS; o vishing, por ligação telefônica; o keylogger é um programa que registra teclas digitadas.

QUESTÃO 08

Ao enviar um comunicado a vários destinatários sem expor os endereços de e-mail de uns aos outros, o guarda deve inseri-los no campo

A Para.
B Cc.
C Cco.
D Assunto.

Gabarito: C.

O campo Cco (cópia oculta) esconde os destinatários entre si, preservando a privacidade. Nos

campos Para e Cc, todos os destinatários veem os endereços uns dos outros. O campo Assunto não é de destinatários.

QUESTÃO 09

Uma máquina foi infectada por um código malicioso que cifrou os arquivos e exige pagamento para devolvê-los. A medida preventiva mais eficaz contra esse tipo de ataque é

A manter backups periódicos, testados e guardados de forma isolada do computador.
B pagar o resgate para garantir a devolução dos dados.
C desativar o firewall para liberar o tráfego de rede.
D usar a mesma senha em todos os serviços para não esquecê-la.

Gabarito: A.

Com backup isolado e testado, a vítima restaura os dados sem negociar com o criminoso. O pagamento não garante a recuperação e financia o crime. Desativar o firewall e reaproveitar a mesma senha aumentam o risco, não o reduzem.

QUESTÃO 10

De acordo com o art. 1º da Lei nº 13.709/2018 (LGPD), a lei dispõe sobre o tratamento de dados pessoais, inclusive nos meios digitais, realizado

A apenas por empresas privadas.
B por pessoa natural ou por pessoa jurídica de direito público ou privado.
C apenas em documentos impressos.
D exclusivamente pela administração federal.

Gabarito: B.

O artigo 1º alcança o tratamento de dados pessoais, inclusive nos meios digitais, por pessoa natural ou por pessoa jurídica de direito público ou privado. Por isso, órgãos públicos também se submetem à lei. As demais alternativas restringem indevidamente o alcance.

11 RESUMO DA VÉSPERA

REVISÃO

REVISÃO

- Princípios: **confidencialidade, integridade, disponibilidade**, acrescidos de **autenticidade**; o **não repúdio** decorre da assinatura digital.
- **Cifrar** com a chave pública do destinatário garante sigilo; **assinar** com a chave privada do autor

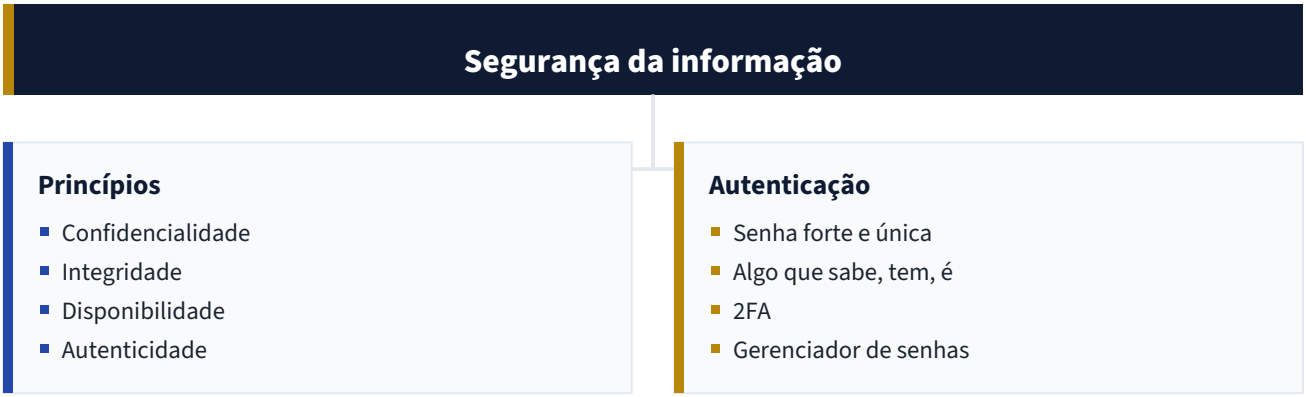
garante autoria e integridade.

- O **hash** serve para conferir a integridade: se o arquivo muda, o resumo muda.
- Senha forte: **longa, variada, sem dados pessoais e exclusiva** para cada serviço.
- **2FA:** fatores de categorias diferentes (saber, ter, ser).
- Backup **completo** copia tudo; **incremental**, o que mudou desde o último backup de qualquer tipo; **diferencial**, desde o último completo.
- Backup bom é **periódico, fora do local e testado**; regra **3-2-1**.
- **Vírus** precisa de hospedeiro; **worm** se espalha sozinho; **cavalo de Troia** se disfarça; **ransomware** pede resgate; **spyware** espiona.
- **Antivírus, firewall e atualizações** se complementam; nenhum dispensa o cuidado do usuário.
- **Phishing** imita instituições; **engenharia social** explora o fator humano; ninguém sério pede senha ou código por mensagem.
- O **cadeado** indica conexão cifrada, não site honesto.
- **LGPD** (Lei nº 13.709/2018) regula o tratamento de dados pessoais, inclusive pelo poder público.
- No serviço público: recurso de TI **só para o trabalho**, **bloqueio da tela** ao sair, **comunicação de incidentes**.

Estudo completo do assunto — material integrado

Esta parte reúne, num só lugar, tudo o que o Bizu do Concurseiro X tem conferido sobre este assunto: o mapa mental, o texto oficial da lei, a jurisprudência atualizada, a doutrina que as bancas cobram, uma bateria de questões resolvidas e a revisão rápida. Use-a depois da leitura da apostila para fixar e treinar.

Mapa mental do assunto



Backup
- Completo
- Incremental
- Diferencial
- Cópia fora do local e teste de restauração

Malware
- Vírus e worm
- Cavalo de Troia
- Ransomware
- Spyware (keylogger)
- Adware

Golpes
- Engenharia social
- Phishing e smishing
- Falso atendente, boleto falso
- Pedido de código de verificação

Privacidade e ética
- Mínimo de dados expostos
- LGPD
- Bloquear a tela
- Uso só para o trabalho

Bateria de questões resolvidas

Questões no padrão da banca, com gabarito e comentário. Tente responder antes de ler o gabarito.

QUESTÃO 1

Um guarda municipal que tem acesso a informações de ocorrências deve agir eticamente na utilização dos recursos de TI. Uma conduta adequada é

A) emprestar a senha a um colega que esqueceu a dele.
B) publicar nas redes sociais dados de pessoas atendidas em ocorrências.
C) salvar documentos sigilosos em equipamentos pessoais sem proteção.
D) manter o sigilo das informações, não divulgá-las em redes sociais e não compartilhar suas credenciais de acesso.
E) deixar a sessão aberta ao se ausentar do computador.

Gabarito: D

A senha é pessoal e intransferível, e os dados de ocorrências são sigilosos. A conduta ética inclui proteger informações e credenciais.

QUESTÃO 2

Para verificar se um link recebido por e-mail é suspeito, uma atitude prudente, antes de clicar, é

A) clicar rapidamente no link e fechar a página caso pareça estranha.
B) posicionar o ponteiro do mouse sobre o link e conferir o endereço real de destino exibido pelo programa.
C) encaminhar a mensagem a todos os contatos, pedindo opinião.

D responder ao remetente, informando o número do CPF para confirmar a identidade, conforme o funcionamento habitual do sistema.

E confiar no link se o texto da mensagem for bem escrito e tiver logotipo.

Gabarito: B

O texto de um link pode ser diferente do endereço real, e conferir o destino ao passar o mouse sobre ele ajuda a identificar fraudes. Um texto bem escrito ou um logotipo podem ser facilmente imitados por golpistas.

QUESTÃO 3

O programa malicioso que permite ao invasor retornar a um computador já comprometido, sem passar pelos mecanismos normais de autenticação, é denominado

A adware.

B cookie.

C backdoor.

D ransomware.

E worm.

Gabarito: C

O backdoor (porta dos fundos) cria um acesso oculto para futuras invasões. Adware exibe propaganda, ransomware sequestra dados mediante resgate, worm se propaga pela rede sozinho e cookie é apenas um pequeno arquivo de dados de navegação, não um programa malicioso.

QUESTÃO 4

Considere as afirmações sobre segurança da informação. I. O worm é capaz de se propagar automaticamente pela rede, sem precisar ser anexado a outro arquivo. II. O cavalo de Troia se apresenta como um programa legítimo ou útil, mas realiza funções maliciosas ocultas. III. Um e-mail com o logotipo de um banco que pede a senha com urgência pode ser considerado confiável, desde que o nome do remetente pareça conhecido. IV. O firewall substitui completamente o antivírus, tornando-o desnecessário. Está correto o que se afirma em

A I, II e III, apenas.

B II e IV, apenas.

C I e III, apenas.

D III e IV, apenas.

E I e II, apenas.

Gabarito: E

I e II são verdadeiras. III é falsa: logotipo, urgência e pedido de senha são sinais típicos de phishing, e o nome do remetente pode ser falsificado; banco nenhum pede senha por e-mail. IV é falsa:

firewall filtra conexões de rede e não substitui o antivírus; os dois se complementam.

QUESTÃO 5

Em um site, o cadeado e o protocolo HTTPS indicam que a conexão é criptografada, mas

A isso não garante, por si só, que o site seja legítimo, pois sites fraudulentos também podem utilizar conexão criptografada.
B isso garante que o site é legítimo e seguro para informar dados pessoais.
C isso garante que o site não possui nenhum tipo de vírus.
D isso significa que o computador do usuário está protegido contra malware.
E isso indica que o site pertence a um órgão do governo.

Gabarito: A

O HTTPS protege os dados em trânsito contra interceptação, mas não prova a idoneidade do site, e golpistas também obtêm certificados. Por isso é preciso conferir o endereço e a origem do link.

QUESTÃO 6

O tipo de malware que se apresenta como um programa aparentemente útil ou legítimo, como um jogo, mas executa ações maliciosas sem o conhecimento do usuário, é o

A cavalo de Troia (trojan).
B firewall.
C antivírus.
D cookie.
E backup.

Gabarito: A

O cavalo de Troia se disfarça de programa legítimo. Antivírus e firewall são ferramentas de proteção, e cookie é um pequeno arquivo de navegação.

QUESTÃO 7

O programa malicioso que coleta informações sobre as atividades do usuário no computador e as envia a terceiros, sem o seu conhecimento, é o

A firewall.
B adware legítimo.
C driver de vídeo.
D firmware.
E spyware.

Gabarito: E

Spyware é o malware que monitora o usuário e transmite dados a terceiros sem consentimento. Firewall é ferramenta de proteção, driver de vídeo e firmware são softwares legítimos de controle de dispositivos, e adware, quando legítimo, exibe propaganda autorizada.

QUESTÃO 8

Para que uma política de cópias de segurança seja confiável, recomenda-se que a restauração dos dados seja

A) testada somente depois que ocorrer a perda dos dados originais.
B) evitada, pois o teste costuma danificar as cópias existentes.
C) feita apenas pelo fabricante do equipamento, que gera as cópias.
D) dispensada, desde que o backup tenha sido concluído sem aviso de erro, conforme o funcionamento habitual do sistema.
E) testada periodicamente, para verificar se as cópias estão íntegras e podem ser recuperadas.

Gabarito: E

Só o teste de restauração mostra se o backup está íntegro e utilizável; descobrir um problema apenas depois da perda de dados pode ser tarde demais. O aviso de conclusão sem erro não garante que a recuperação funcionará.

QUESTÃO 9

Um backup diferencial copia

A) apenas os arquivos excluídos desde o último backup completo.
B) somente os arquivos alterados desde o último backup de qualquer tipo.
C) os arquivos novos ou alterados desde o último backup completo.
D) somente os arquivos que estão abertos no momento da cópia.
E) todos os arquivos do computador, a cada execução.

Gabarito: C

O backup diferencial acumula tudo o que mudou desde o último backup completo, ao passo que o incremental copia o que mudou desde o último backup de qualquer tipo. Copiar todos os arquivos a cada execução é característica do backup completo.

QUESTÃO 10

Utilizar a mesma senha em vários serviços na internet é uma prática desaconselhada porque

A) o vazamento da senha em um serviço pode comprometer as contas do usuário em todos os outros que a utilizam.
B) o número de serviços que aceitam senhas repetidas é muito reduzido.
C) senhas repetidas deixam o computador lento em todos os acessos.
D) as senhas repetidas são apagadas pelos navegadores depois de alguns dias.
E) a repetição impede o uso de autenticação em dois fatores.

Gabarito: A

Reutilizar senhas amplia o dano de um vazamento: quem obtém a senha de um serviço pode tentar usá-la em outros. A repetição não torna o computador lento nem impede a autenticação em dois fatores.

Revisão rápida — perguntas e respostas

Pergunta	Resposta
Qual malware se espalha sozinho pela rede, sem hospedeiro?	Worm.
Qual malware criptografa arquivos e pede resgate?	Ransomware.
Senha + código no celular é exemplo de quê?	Autenticação de dois fatores (2FA).
Backup que copia tudo o que mudou desde o último completo?	Diferencial.
Golpe de mensagem falsa por SMS se chama?	Smishing.
Qual pilar garante que a informação não foi alterada indevidamente?	Integridade.

Vídeos complementares

Se algum ponto não ficou claro na leitura, estes vídeos curtos e selecionados explicam direto ao ponto. Clique para abrir.

Resumo DIRETO AO PONTO - Segurança da informação - Informática Concursos \| Danilo Vilanova #opior ASSISTIR

Professor Danilo Vilanova | Informática Concursos

https://youtu.be/X2wgk02Bqt0